Table S1. Security Scoring Rubric and Criterion Definitions

Scale: 1 = Low Risk; 2 = Some Concerns; 3 = High Risk. Each numbered criterion represents a specific privacy practice assessed across manufacturers.

Criterion	Dimension	Definition	Indicators	Risk Level Scoring Insight
User Notification About Third-Party Requests	Transparency (1-4)	Evaluates whether companies notify users when government or private third parties request access to their personal data.	Explicit notification policies for government or private third-party requests. Disclosure of situations in which notification is legally restricted (e.g., gag orders).	**High Risk:** No mention of user notification in case of third-party data requests. Policy is silent on legal exceptions or fails to mention the existence of transparency reporting mechanisms. **Low Risk:** The company clearly commits to notifying users of third-party data requests when legally permissible. Disclosure includes specific mention of both government and private requests and outlines situations when notification is restricted. **Some Concerns:** Policy contains vague or ambiguous statements (e.g., "we may disclose your data as required") without clarifying notification procedures or user rights.
Transparency Reporting	Transparency (1-4)	Evaluate the company's transparency regarding its data-sharing practices with governments and other third parties.	Number of requests received by country. Types of data requested (e.g., metadata vs. content). Number of user accounts affected. Legal basis for the request (e.g., subpoena, court order).	**High Risk:** No transparency report or section in the privacy policy addressing government data requests. Failure to disclose volume, scope, or legal basis of requests. **Low Risk:** Regularly published transparency reports disclosing all four indicators above. Reports are clearly accessible and comprehensible to users. **Some Concerns:** Reporting exists but lacks sufficient detail or omits key elements (e.g., no legal basis or affected account count provided).
Threat Notification	Transparency (1-4)	Evaluates whether the company notifies users and authorities in case of a data breach.	Timely breach notification policy. Description of user notification process. Post-breach user support or mitigation procedures.	**High Risk:** No policy on breach notification or one that only commits to authority notification without mention of users. No time frame for notification or user recourse. **Low Risk:** Clearly defined breach notification procedures including timelines. Explicit commitment to notify affected users and provide mitigation resources. **Some Concerns:** Vague commitment to "inform users when appropriate" without defining criteria or processes.
Identity Policy	Transparency (1-4)	Assesses whether users can register and use the service without providing government-issued identification.	Registration process does not require government ID. Users can use pseudonyms or anonymized identifiers.	**High Risk:** Government-issued ID required to register or access core features. Real-name policies enforced without clear justification. **Low Risk:** Users can register and use core functionality without ID. Anonymous or pseudonymous access explicitly allowed. **Some Concerns:** Policy does not address identification requirements, or the registration process is ambiguous.
Data Use	Data Collection Purpose (5-9)	Evaluates whether the company limits data usage to clearly defined, appropriate purposes aligned with the user relationship.	Data uses are fully disclosed in the privacy policy. Uses are consistent with the stated purposes of the product. No repurposing of data for unrelated objectives (e.g., advertising, profiling, resale) without explicit consent.	**High Risk:** Data use is vaguely defined or includes unrelated secondary purposes without consent. The company claims broad discretion to use data for undefined business purposes. **Low Risk:** All data uses are clearly listed and limited to purposes that align with core product functionality or user benefit. Secondary uses (e.g., analytics, research, advertising) are disclosed and subject to opt-in consent. **Some Concerns:** The policy refers to data uses generically (e.g., "to improve services") without specifying what data is used or for which functions.
Data Collection	Data Collection Purpose (5-9)	Assesses how clearly the company discloses the types of data collected, how they are collected, and when.	A full list of data types (e.g., heart rate, location, contacts). Specification of the data source (device sensors, user input, third parties). Timing of data collection (real-time, periodic, background).	**High Risk:** No clear disclosure of data types or collection methods. Third-party data ingestion is mentioned without explanation. **Low Risk:** The company provides a detailed table or breakdown of data collected, when it is collected, and via what mechanism. Third-party data collection is clearly explained. **Some Concerns:** The policy lists broad categories (e.g., "health data" or "usage data") without examples, sources, or technical context.
Minimal Data Collection	Data Collection Purpose (5-9)	Evaluates whether the company adheres to the principle of data minimisation—only collecting what is necessary.	Statement committing to minimal data collection. Clear option to disable non-essential permissions without product degradation. Explanation of data necessity per feature.	**High Risk:** Data is collected broadly, without justification, and with no opt-out or controls. Disabling permissions leads to loss of core functionality. **Low Risk:** Non-essential data collection is optional and clearly indicated. Core product functionality remains intact when optional permissions are denied. **Some Concerns:** The policy is silent on what constitutes "necessary" data. No differentiation between essential and non-essential permissions.
Privacy by Default	Data Collection Purpose (5-9)	Assesses whether default settings are configured to maximize user privacy at first use.	Default opt-out from targeted advertising or third-party data sharing. Data sharing is disabled until actively enabled by the user.	**High Risk:** Defaults enable extensive data collection, tracking, or third-party sharing. No explanation of default configurations. **Low Risk:** Privacy-protective settings are enabled by default (e.g., tracking disabled, minimal data sharing). Settings can be modified but are off by default. **Some Concerns:** Defaults are not stated, or privacy controls are buried behind unclear or difficult-to-reach interfaces.
Data Benefits	Data Collection Purpose (5-9)	Evaluates whether the company explains how each category of collected data benefits the user or product experience.	Explanation of how collected data enhances product functionality, performance, or personalization. Mapping of data types to benefits.	**High Risk:** No rationale is provided for why data is collected. Benefits are framed in vague or promotional language (e.g., "to improve your experience") without specificity. **Low Risk:** Each data type is linked to a specific function or user benefit. Benefits are framed in user-centric, non-technical language. **Some Concerns:** Policy references "benefits" or "functionality" but does not specify what data is required or why.
Purpose Limitation	Data minimization (10-12)	Assesses whether the company collects data only for clearly defined, legitimate purposes and does not reuse data in ways incompatible with the original purpose.	Clear purpose statements for each data type collected. Explicit prohibition of repurposing data beyond the original user context without consent.	**High Risk:** Vague, open-ended language suggesting data may be used for "business interests" or "future developments." No stated purpose or only general business process justification. **Low Risk:** Specific purposes are defined for each type of data collected. The company affirms that data will not be used for unrelated purposes without further consent. **Some Concerns:** Data collection purposes are referenced generically (e.g., "to enhance the user experience") without linkage to specific data types.
User Control Over Data Collection	Data minimization (10-12)	Evaluates whether users have meaningful control over non-essential data collection.	Settings to disable optional data collection. Ability to use core product features even when optional permissions are denied.	**High Risk:** Users are forced to enable all data collection to access even basic features. No mechanism to opt out of non-essential permissions. **Low Risk:** Users can deny access to location, contacts, or other non-essential data without losing core functionality. Data collection toggles are easily accessible. **Some Concerns:** Privacy settings exist, but it is unclear whether disabling them affects essential product functions.
Data Retention	Data minimization (10-12)	Assesses whether the company limits how long personal data is retained and whether it offers timely deletion or anonymization.	Clear retention periods by data type. Mechanisms to delete or anonymize data after it is no longer needed. Disclosure of legal or operational reasons for data retention.	**High Risk:** No stated data retention limits. Company reserves the right to retain personal data indefinitely or without justification. **Low Risk:** Company specifies time-bound retention (e.g., 90 days, 1 year) and provides accessible deletion tools. Clear process for automatic deletion or anonymization. **Some Concerns:** Policy references "as long as necessary" or "per legal requirements" without further clarification or examples.
Data Control	User control/rights (13-16)	Evaluates whether users have the ability to access and manage how their personal data is collected, processed, and shared.	Availability of controls via web, desktop, or mobile platforms. Granular options to enable/disable specific data types or sharing functions. Settings that are clearly labeled and easily navigable.	**High Risk:** Users cannot adjust data collection or sharing settings. Settings exist only as an illusion of control (e.g., toggles with no documented effect). **Low Risk:** Users can modify settings related to health, location, or device usage data. Full control is provided within product interfaces, with supporting guidance. **Some Concerns:** Settings exist but are either buried, inconsistently described, or do not clarify their functional impact on data flows.
Control Over Targeted Advertising	User control/rights (13-16)	Assesses whether users can opt out of targeted or personalized advertising based on their personal data.	Dedicated opt-out mechanism for advertising-related profiling. Clear separation between functional data use and commercial use.	**High Risk:** Policy states that data may be used for targeted advertising without opt-out. Users are opted in by default with no explanation. **Low Risk:** Users are opted out of targeted advertising by default and may opt in. A straightforward toggle is available to disable advertising personalization. **Some Concerns:** Advertising data use is discussed vaguely, with no clear mention of user control mechanisms.
Data Access	User control/rights (13-16)	Evaluates whether users can access their own data and receive it in a structured, portable format.	Description of what types of personal data are available upon request. Delivery formats that meet portability standards (e.g., JSON, CSV). Defined timeframes for responding to access requests.	**High Risk:** No provision for data access. Data access requests are subject to discretionary approval or undefined process. **Low Risk:** Full disclosure of accessible data types and delivery in standard, machine-readable format. Specific turnaround time and procedures are stated. **Some Concerns:** Mention of a "right to access" with no detail about what data is included or how it is delivered.
Data Deletion	User control/rights (13-16)	Assesses whether users can delete their data and whether deletion practices are consistent and effective.	Users can delete all or selected portions of their data. Clear description of what happens to deleted data (e.g., permanent erasure vs. archival). Deletion tools are easily accessible and irreversible.	**High Risk:** No user-initiated deletion mechanism. Company retains discretion over deletion timing or scope. **Low Risk:** Deletion tools are prominently available and processed in a timely manner. Deletion includes both device-side and cloud-side data. **Some Concerns:** The term "delete" is used but not clearly defined; no clarity on whether deletion is complete or partial.
Data Sharing	3rd party data sharing (17)	Evaluates whether the company discloses what data is shared with third parties, under what conditions, and with what safeguards.	Clear list or description of what data types are shared. Identification of recipient categories (e.g., advertisers, affiliates, cloud providers). Justification for sharing, and whether sharing is necessary or optional. Specific mention of whether data is shared with government entities, and under what legal basis.	**High Risk:** Data sharing is acknowledged, but no details are provided about what is shared, with whom, or why. No control is provided to the user, and sharing includes sensitive health or biometric data. Government or law enforcement access is not addressed or is unrestricted. **Low Risk:** All shared data categories are disclosed, and recipients or recipient types are identified. Data sharing is limited to what is necessary for core functions or user-approved services. Government access is disclosed transparently, with reference to legal basis and safeguards. **Some Concerns:** Terms like "trusted partners," "service providers," or "affiliates" are used without explanation. It is unclear whether data is shared with third parties at all, or what safeguards apply.
Authentication	Data Security (18-23)	Assesses the strength and flexibility of the authentication mechanisms required to access user data or device features.	Support for multi-factor authentication (MFA). Requirement of authentication for accessing sensitive data. Protection against brute-force attacks (e.g., rate-limiting, lockout policies).	**High Risk:** No mention of authentication beyond a basic password. No MFA offered or required, even for cloud account or sensitive data access. No measures described to protect against brute-force or unauthorized access attempts. **Low Risk:** MFA is supported and encouraged for user accounts. Sensitive actions (e.g., health data export, settings changes) require re-authentication. Technical safeguards are described to prevent credential attacks. **Some Concerns:** Authentication methods are not mentioned, or only referenced without implementation detail.
Encryption	Data Security (18-23)	Evaluates whether user data is encrypted both in transit and at rest, and whether end-to-end encryption is available or enabled.	AES or equivalent encryption at rest. TLS/SSL encryption for data in transit. End-to-end encryption (E2EE) for sensitive data. Policy includes technical encryption specifications.	**High Risk:** No mention of encryption, or only vague language (e.g., "we take security seriously"). Data is stored or transmitted without encryption, or practices are unclear. **Low Risk:** Explicit commitment to encryption at rest and in transit. E2EE available or enabled for health-related or sensitive biometric data. **Some Concerns:** Encryption is referenced generally, but details are omitted or ambiguous. No mention of whether E2EE is implemented or optional.
Known Exploit Resistance	Data Security (18-23)	Assesses whether the product includes measures to protect against known vulnerabilities.	Security testing or audits referenced in the policy. Commitment to addressing OWASP Top Ten or similar exploit classes. Secure software development practices or patching cycle described.	**High Risk:** No mention of known vulnerabilities or software security practices. No evidence that the company responds to reported technical threats. **Low Risk:** Company references secure development practices and actively tracks known exploit types. Policy or documentation includes links to vulnerability bulletins or security advisories. **Some Concerns:** Security language is generic (e.g., "we regularly test our systems") without specific threat models or practices.
Security Oversight	Data Security (18-23)	Evaluates whether internal controls are in place to limit and monitor access to user data, and whether third-party audits are conducted.	Role-based access control (RBAC) policies. Activity logging and access monitoring. Use of independent security assessments or audits.	**High Risk:** No mention of internal access policies or third-party oversight. Broad or unrestricted employee access to user data is implied or allowed. **Low Risk:** Access to personal data is restricted, logged, and audited. Third-party security assessments or SOC 2/ISO certifications are disclosed. **Some Concerns:** Policy mentions "data protection" or "safeguards" but omits access controls or oversight structure.
Security Over Time	Data Security (18-23)	Assesses whether the company ensures the long-term security of devices and systems through patches, communication, and lifecycle support.	Automatic security updates enabled or available. Disclosure of support period or product lifecycle policy. Notification to users when a device reaches end-of-support.	**High Risk:** No mention of updates, patching, or device support timelines. Devices may remain online with known vulnerabilities after support ends. **Low Risk:** Clear update schedule, automatic patching, and transparent end-of-support communications. Commitment to support products for a defined number of years. **Some Concerns:** Updates are mentioned but it is unclear whether they are security-related or how long devices are supported.
Vulnerability Disclosure Program	Data Security (18-23)	Assesses whether the company has a formal process to receive, verify, and remediate reported vulnerabilities from researchers or the public.	Public vulnerability disclosure page or bug bounty program. Defined response timeline or process for disclosure triage. Acknowledgement of researcher contributions.	**High Risk:** No disclosure process mentioned. External reports are discouraged or explicitly unwelcome. **Low Risk:** Public policy exists, with defined response windows and responsible disclosure support. Bug bounty programs or hall-of-fame acknowledgements in place. **Some Concerns:** Disclosure is referenced, but no public process or contact channel is provided.
Breach Notification	Breach notification (24)	Assesses whether the company commits to notifying both relevant authorities and affected users in the event of a data breach, and whether the notification procedures are clear and timely.	Commitment to notifying data protection authorities promptly (e.g., within 72 hours, per GDPR Art. 33). Clear procedures for notifying users, including timelines and communication channels. Explanation of the type of breach, data affected, mitigation steps, and user support.	**High Risk:** No mention of breach notification procedures for either users or authorities. Company reserves the right to decide if and when to notify, without defined triggers or timelines. **Low Risk:** Clear and timely breach notification policies, with stated timelines (e.g., 72 hours). User communication includes actionable information and support resources. Legal thresholds for notification are respected and disclosed. **Some Concerns:** Policy includes generic language (e.g., "we take security seriously") with no specific detail on breach handling. Breach is referenced but only in a legal context, without user-level clarity or action plan.